> **位置**：总索引 | **上游**：I/O 管理与系统调用（OS 07） | **下游**：网络安全（下）（安全 02）
>
> 本篇覆盖原笔记第 1–6 章；下篇覆盖第 7–12 章。

# 1. 信息安全基本目标与网络空间

## 1.1 信息安全基本目标：CIA

信息安全的三个基本目标是机密性 (Confidentiality)、完整性 (Integrity) 和可用性 (Availability)，即 CIA。

**什么是信息安全**：信息本身的机密性、完整性和可用性的保持（一分），即防止未经授权使用信息（一分）、防止对信息的非法修改和破坏（一分）、确保及时可靠地使用信息（一分）。

| 属性 | 含义 |
| --- | --- |
| 机密性 | 确保信息没有非授权的泄漏，不被未授权的个人、组织和计算机程序使用 |
| 完整性 | 确保信息没有遭到篡改和破坏 |
| 可用性 | 确保拥有授权的用户或程序可以及时、正常使用信息 |

## 1.2 网络空间的定义

网络空间是由四个核心要素构成的人造活动空间：设施（信息通信技术系统）、数据（广义信号）、用户（网络角色）和操作（信息通信技术活动）。

| 要素 | 角色 |
| --- | --- |
| 网络空间载体 | 设施，信息通信技术系统的集合 |
| 网络操作对象 | 数据，表达人类所能理解的意图的信号状态 |
| 网络活动主体 | 用户，网络活动的主体要素，属于人的代理 |
| 网络活动形式 | 操作，对数据的加工、存储、传输、展示等服务形式 |

## 1.3 网络空间的一般性定义

一般性定义是根据《国家网络空间安全战略》给出的定义：

> 网络空间是一种人造的电磁空间，其以互联网、各种通信系统与电信网、各种传播系统与广电网、各种计算机系统、各类关键工业设施中的嵌入式处理器和控制器等信息通信技术基础设施为载体，用户通过在其上对数据进行创造、存储、改变、传输、使用、展示等操作，以实现特定的信息通信技术活动。

## 1.4 网络空间安全

网络空间安全涉及保护网络空间中的信息通信技术系统及其所承载的数据免受攻击，同时也要防止对这些系统的运用或滥用波及政治安全、经济安全、文化安全、社会安全、国防安全等情况的发生。

## 1.5 网络空间安全的四层次模型

任何信息系统都会涉及四个层面：电磁设备、电子信息系统、运行数据、系统应用。自顶向下：

| 层次 | 应对的安全问题 | 包括 |
| --- | --- | --- |
| 应用层的安全 | 应对在信息应用的过程中所形成的安全问题 | 内容安全、应用安全等 |
| 数据层的安全 | 应对在网络空间中处理数据的同时所带来的安全问题 | 数据安全、身份安全、隐私保护等 |
| 系统层的安全 | 应对在网络空间中信息系统自身所面对的安全问题 | 网络安全、软件安全等 |
| 设备层的安全 | 应对在网络空间中信息系统设备所面对的安全问题 | 物理安全、环境安全、设备安全等 |

# 2. 网络空间安全风险管理及国产化替代

## 2.1 第一部分：网络空间安全风险管理

### 2.1.1 什么是网络空间安全风险管理?

**定义 1（GB/Z 24364《信息安全风险管理指南》）**：信息安全风险管理是识别、控制、消除或最小化可能影响系统资源的不确定因素的过程。

**定义 2（通用）**：在组织机构内部识别、优化、管理风险，使风险降低到可接受水平的过程。

**核心目标**：了解风险 → 控制风险 → 将风险降至可接受水平。

### 2.1.2 网络空间安全风险术语（名词解释必背）

| 术语 | 定义 | 要点 |
| --- | --- | --- |
| **资产**（Asset） | 任何对组织有价值的东西，是要保护的对象 | 分类：物理的/逻辑的；硬件的/软件的；有形的/无形的；静态的/动态的；技术的/管理的 |
| **威胁源**（Threat Agent） | 可能对资产或组织造成损害的事件的潜在原因 | — |
| **威胁**（Threat） | 指可能对信息系统资产造成损害的潜在事件、行为或现象 | 来源为威胁源，<br>需与系统脆弱性结合才可能引发实际安全风险 |
| **脆弱性**（Vulnerability） | 与信息资产有关的弱点或安全隐患，<br>是造成风险的内因 | 例如：代码缺陷、配置错误、流程缺陷、安全意识不足 |
| **控制措施**（Countermeasure / Safeguard / Control） | 根据安全需求部署，用来防范威胁、降低风险的措施 | 例如：防火墙、入侵检测、审批环节、应急体系 |
| **可能性**（Likelihood / Probability） | 威胁源利用脆弱性造成不良后果的可能性 | 漏洞利用难度小 → 可能性高；系统隔离运行 → 可能性低 |

| 术语 | 定义 | 要点 |
| --- | --- | --- |
| **影响**（Impact / Loss） | 威胁源利用脆弱性造成不良后果的程度大小 | 国家级网站被黑比省市网站影响更大 |
| **风险**（Risk） | 威胁源采用恰当的威胁方式利用脆弱性造成不良后果 | 核心公式：**风险 = 威胁 × 脆弱性 × 资产价值** |
| **残余风险**（Residual Risk） | 采取了安全措施后，信息系统仍然可能存在的风险 | — |

风险（国标定义 GB/T 20984）：人为或自然的威胁利用信息系统及其管理体系中存在的脆弱性导致安全事件的发生及其对组织造成的影响。

### 2.1.3 风险评估、检查评估和等级保护测评之间的关系

| 类型 | 含义 |
| --- | --- |
| 风险评估 | 系统性分析威胁、脆弱性，评估风险等级，提出防护对策 |
| 检查评估 | 针对特定安全要求或标准进行检查 |
| 等级保护测评 | 依据国家等级保护标准，对信息系统进行合规性测评 |

**三者关系**：风险评估是基础，检查评估和等级保护测评是特定形式的评估，侧重于合规与检查。

### 2.1.4 风险评估实施流程（四阶段）

| 阶段 | 内容 |
| --- | --- |
| 评估准备 | 确定评估目标、范围、组建团队 |
| 风险识别 | 识别资产、威胁、脆弱性、现有控制措施 |
| 风险分析 | 定性分析：用"高、中、低"等级描述风险（主观、快速）<br>定量分析：用数值（如金额）描述风险，如 ALE（年度损失期望）= SLE（单次预期损失）× ARO（年度发生率）（客观、复杂）<br>综合评估法：结合定性与定量 |
| 风险处理 | 根据风险等级选择处置措施 |

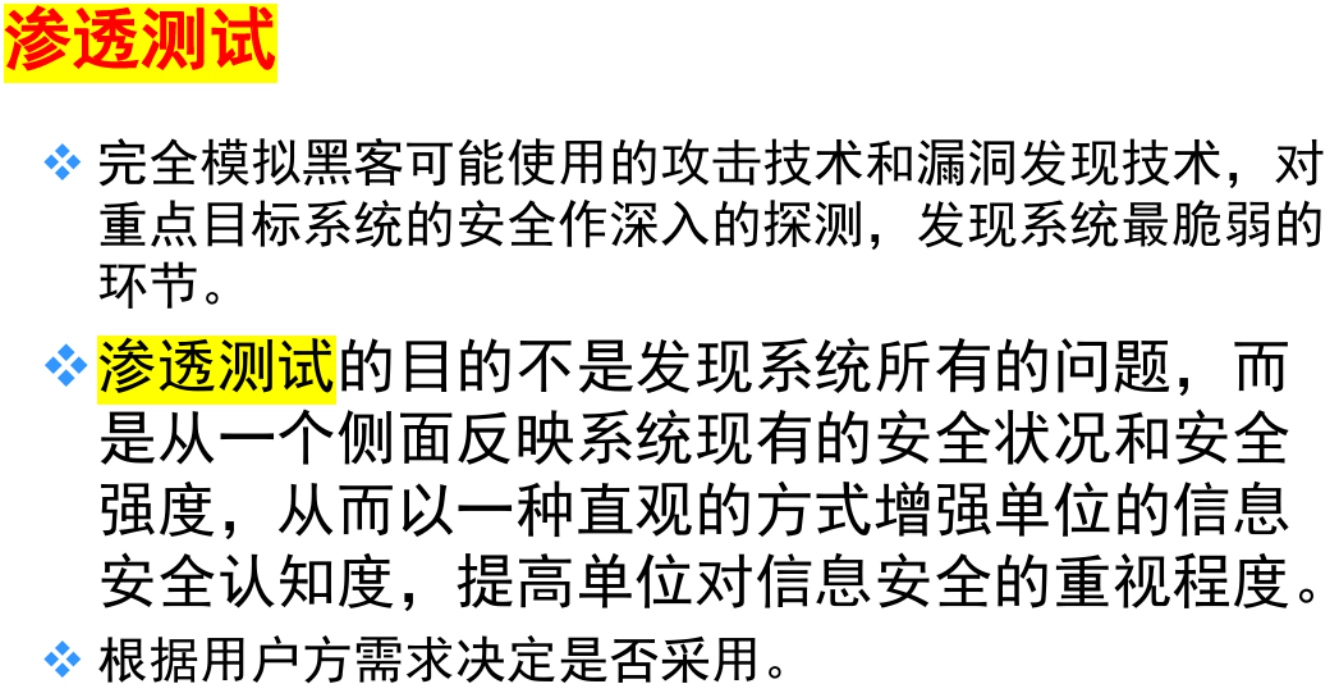
### 2.1.5 风险处理（四类方法）

| 方法 | 做法 |
| --- | --- |
| **减低风险** | 采取控制措施降低风险（如安装防火墙、打补丁）。具体做法：减少威胁源、降低威胁能力、减少脆弱性、防护资产、降低负面影响 |
| **转移风险** | 将风险转移给第三方（如购买保险、技术外包） |
| **规避风险** | 放弃可能产生风险的活动（如关闭高风险服务、不使用互联网） |
| **接受风险** | 在成本效益分析后，主动承担风险（需持续监控） |

### 2.1.6 脆弱性识别与渗透测试

**脆弱性识别**：识别系统中存在的弱点或安全隐患（如代码漏洞、配置错误、管理缺陷）。

**渗透测试**：模拟黑客攻击，验证系统脆弱性是否可被利用。




### 2.1.7 风险分析

分析威胁利用脆弱性的可能性和影响程度，确定风险等级。

### 2.1.8 风险管理的工作内容（四个阶段 + 两个贯穿）

依据 GB/Z 24364《信息安全风险管理指南》：

| 环节 | 内容 |
| --- | --- |
| 建立背景 | 确定风险管理对象、范围、组建团队、制定计划 |
| 风险评估 | 风险分析准备 → 风险要素识别 → 风险分析 → 风险结果判定 |
| 风险处置 | 判断现存风险 → 确认处理目标 → 选择处理措施 → 实施控制措施 |
| 批准监督 | 管理层审批残余风险，监督措施执行 |
| 监控审查（贯穿全程） | 持续监控风险变化，定期审查 |
| 沟通咨询（贯穿全程） | 与各方保持沟通，获取支持与反馈 |

> 风险管理 > 风险评估 > 风险分析

### 2.1.9 其他考点：风险评估工具

由风险评估工具得到风险评估的结果。

**风险评估与管理工具（标准、知识、模型）**

- 基于标准的工具，如基于 NIST SP 800-30 或 ISO 27005 开发的工具
- 基于知识的工具，综合各种风险分析方法，形成知识库，以此为基础完成综合评估
- 基于模型的工具，对典型系统的资产、威胁、脆弱性建立量化或半量化的模型

**系统基础平台风险评估工具**

- 脆弱性扫描工具（漏扫）：基于网络的扫描器、基于主机的扫描器、分布式网络扫描器、数据库脆弱性扫描器
- 渗透性测试工具：黑客工具、脚本文件

**风险评估辅助工具**：检查列表、入侵检测系统（IDS）、安全审计工具、拓扑发现工具和资产信息收集系统，用于评估过程参考的评估指标库、知识库、漏洞库、算法库和模型库。

# 2.2 第二部分：国产化替代（信创）

## 2.2.1 国产化替代的核心定义与必要性

**定义**：用国产自主可控产品替代被垄断的国外产品。

**必要性（为什么要国产化替代）**：应对供应链安全危机（如华为、中兴事件），打破国外在芯片、基础软件等领域的垄断；或者实现核心技术自主可控，规避依赖导致的风险。

## 2.2.2 主要替代内容（"替什么"）

国产桌面计算机技术体系对 **Wintel 体系**的替代；高端服务器和数据库对 **"IOE"** 的替代。

- 这里的 **"Wintel 体系"** 指的是微软的 Windows 操作系统和英特尔的处理器技术体系，
- 而 **"IOE"** 通常指的是 IBM 的硬件（大型计算机）、甲骨文（Oracle）的数据库软件以及 EMC 的存储设备。

| 层面 | 替代内容 |
| --- | --- |
| 底层硬件 | 替代 Intel/AMD CPU，采用国产 CPU（龙芯、飞腾、申威等） |
| 操作系统 | 替代 Windows，发展国产 Linux 发行版（麒麟、统信 UOS） |
| 企业级系统 | 替代国外"IOE"体系（IBM 服务器、Oracle 数据库、EMC 存储设备） |

## 2.2.3 信创产业（"怎么替"）

信创：信息技术应用创新产业，目标是建立中国自主的 IT 底层架构和生态。核心产业链（自下而上）：

1. **底层硬件**（芯片、存储）
2. **基础软件**（操作系统、驱动、数据库、中间件）
3. **应用软件**（办公 OA、ERP、行业软件）
4. **信息安全产品**（边界安全、终端安全）

## 2.2.4 总结

- 风险管理是 **PDCA 循环**（建立背景、风险评估、风险处置、批准监督 + 监控审查、沟通咨询）。
- 风险术语需背全，特别是 **资产、威胁、脆弱性、风险、残余风险。**
- 风险评估流程四阶段：准备 → 识别 → 分析 → 处理。
- 风险处置四策略：减低、转移、规避、接受。

- 国产化替代是 **硬件 → 操作系统 → 企业系统** 的全面替代；信创产业链涵盖 **硬件 → 基础软件 → 应用软件 → 安全产品**。

### 2.2.5 【应试背诵要点与预测考点】

- **名词解释**：风险、脆弱性、ALE、信创、国产化替代。
- **简答题**：
  - 简述风险管理 PDCA 过程的六个步骤。
  - 风险评估的四个基本步骤是什么？
  - 风险处置的四种策略，并各举一例。
  - 定性风险分析与定量风险分析的区别与特点。
  - 为什么说国产化替代是网络安全的基础？（结合必要性答）
- **计算/分析题**：可能给场景数据，要求计算 ALE。
- **论述题要点**：结合"IOE"替代和信创产业链，论述我国实现信息技术自主可控的路径。

# 3. 信息与网络空间安全保障

## 3.1 第一部分：网络空间安全保障背景

### 3.1.1 信息的性质（8 性，理解即可）

依附性、动态性、可处理性、共享性、可传递性、异步性、可交换性、可伪性。网络空间安全的任务是确保信息功能的正确实现。

### 3.1.2 网络空间安全的核心属性（CIA，必背）

| 属性 | 说明 |
| --- | --- |
| 保密性 (Confidentiality) | 防止信息泄露 |
| 完整性 (Integrity) | 防止信息被篡改或破坏 |
| 可用性 (Availability) | 确保授权用户能访问信息和系统 |

> 信息与网络空间安全的核心在于保障数据/信息流的 CIA 属性。

### 3.1.3 网络空间安全发展阶段（了解顺序）

通信安全（COMSEC）→ 计算机安全（COMPUSEC）→ 信息系统安全（INFOSEC）→ 信息安全保障（IA）→ 网络空间安全（CS）。

## 3.2 第二部分：核心安全模型（重点考点）

**名词解释：什么是网络空间安全模型？** 通过建模的思想来解决网络安全管理问题，有效抵御外部攻击，保障网络安全。安全模型用于精确和形式地描述信息系统的安全特征，解释系统安全相关行为。

#### 为什么需要安全模型（简答题可能考）

- 能准确地描述安全的重要方面与系统行为的关系。（模型的处理方式，更能抓住重点）
- 能提高对成功实现关键安全需求的理解层次。（层次化、分段化的模型利于问题的处理）
- 从中开发出一套安全性评估准则，和关键的描述变量。（标准化、规则化处理）

### 3.2.1 PDR 模型（基础）

**出发点**：任何防护措施都是基于时间的，是可以被攻破的。

| 环节 | 说明 |
| --- | --- |
| 保护 (Protection) | 采用加密、防火墙、访问控制等技术防护 |
| 检测 (Detection) | 利用入侵检测、漏洞扫描等技术发现威胁 |
| 响应 (Response) | 事件发生后采取的措施，如应急响应、追踪，对抗入侵 |

三者循环联动。

### 3.2.2 PDR 模型的演变

**PDRR 模型**：在 PDR 基础上增加**恢复 (Restore)**，强调系统被入侵后的恢复能力。恢复（Restore）——系统被入侵后，采取措施将其恢复到正常状态。

**PPDR 模型**：PPDR = policy + protect + detect + response，强调控制和对抗（系统安全的动态性），以安全检测、漏洞监测和自适应填充"安全间隙"为循环，特别考虑人为的管理因素。

- 在 PDR 基础上增加**策略 (Policy)**，强调所有活动在统一安全策略的控制和指导下进行。
- **policy（策略）是模型的核心**；所有的防护、检测、响应都是依据安全策略实施的；策略体系的建立包括安全策略的制定、评估与执行等。
- 策略包括访问控制策略、加密通信策略、身份认证策略、备份恢复策略……

### 3.2.3 PDR 模型的数学法则（必考公式）

**关注时间关系**

$$P_t > D_t + R_t$$

| 变量 | 含义 |
| --- | --- |
| $P_t$ | 防护时间，即防御系统有效抵抗攻击的时间 |
| $D_t$ | 检测时间，从攻击开始到被检测到的时间 |
| $R_t$ | 响应时间，从检测到攻击到完成响应处置的时间 |

另外 $E_t$ 是暴露时间。如果 $P_t > D_t + R_t$，那么系统是安全的；如果 $P_t < D_t + R_t$，那么 $E_t = (D_t + R_t) - P_t$。

**安全判定**：当防护时间大于检测与响应时间之和时，系统被认为是安全的。

### 3.2.4 信息技术保障框架（IATF）和深度防御模型

**核心思想**：承认没有绝对安全，采用多层次、多角度的综合防护措施（人、技术、操作），实现"深度防御"。

| 要素 | 内涵 |
| --- | --- |
| 人 | 核心要素，也是最脆弱的环节。包括安全意识培训、组织管理等 |
| 技术 | 实现保障的手段，包括防护、检测、响应、恢复等技术体系 |

| 要素 | 内涵 |
| --- | --- |
| 操作 | 将技术与人结合的日常运行活动，如风险评估、安全监控、审计等 |

| 人员 | 技术 | 操作 |
| --- | --- | --- |
| 培训 | 深度防御技术框架域 | 分析 |
| 意识 | 安全标准 | 监视 |
| 物理安全 | 获得IA/TA | 入侵检测 |
| 人员安全 | 风险分析 | 警告 |
| 系统安全管理 | 证书与鉴别 | 恢复 |

# 课堂练习

关于信息保障技术框架（IATF），下列哪种说法是错误的？

A、IATF强调深度防御，关注本地计算环境、区域边界、网络和基础设施、支撑性基础设施等多个领域的安全保障

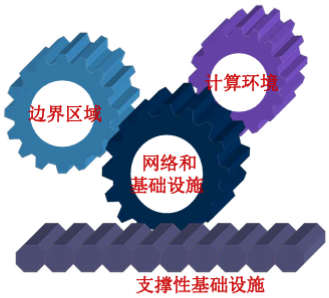
B、IATF强调深度防御，即对信息系统采用多层防护，实现组织的业务安全运作

C、IATF强调从技术、管理和人等多个角度来保障信息系统的安全

D、IATF强调的是以安全检测、漏洞监测和自适应填充“安全间隙”为循环来提高网络安全

## IATF的安全需求划分

- IATF定义了四个主要的技术焦点领域：
  - 本地计算环境
  - 区域边界
  - 网络和基础设施
  - 支撑性基础设施




- 这四个领域构成了完整的信息保障体系所涉及的范围

- 在每个领域范围内，IATF都描述了其特有的安全需求和相应的可供选择的技术措施

**四个技术焦点领域（必背，三保护一支撑）**

| 领域 | 目标 | 举例 |
| --- | --- | --- |
| 保护本地计算环境 | 保护客户机和服务器的数据安全 | 主机入侵检测、防病毒 |
| 保护区域边界 | 控制与监视进出安全区域的数据流 | 防火墙、边界入侵检测 |
| 保护网络和基础设施 | 保证网络通信的可用性、防止数据非法泄露 | 骨干网可用性、VPN |
| 支撑性基础设施 | 为安全服务提供基础支撑 | 密钥管理基础设施、检测响应基础设施 |

在此基础上，对信息信息系统就可以做到多层防护，实现组织的任务/业务运作。这样的防护被称为 **"深度防护战略（Defense-in-Depth Strategy）"**。

成功的组织功能依赖于信息安全保障，通过深度防御战略，融合人、技术、操作三要素，并依托计算环境、区域边界、网络基础设施和支撑性基础设施四个焦点领域来实现。

### 3.2.5 【应试背诵要点与预测考点】

- **名词解释**：CIA 三性、PPDR 模型、IATF 深度防御。
- **简答题**：
  - 简述 PDR 模型及其演变（PDRR、PPDR）。
  - 解释 PPDR 模型中 $P_t > D_t + R_t$ 公式的含义与安全意义。
  - 简述 IATF 深度防御的核心思想与四个技术焦点领域。
  - 列出网络安全事件的分级（四级）及参考标准。
- **论述/分析题**：结合 IATF 模型，论述如何从技术、管理、人员多个层面构建纵深防御体系。

## 3.3 第三部分：应急响应与事件管理

### 3.3.1 计算机安全事件定义

由于自然或人为，以及软硬件本身缺陷或故障的原因，对信息系统造成危害，或在信息系统内发生对社会造成负面影响的事件。

常见的一些计算机安全事件如：

- 窃取商业机密
- 垃圾邮件或邮件骚扰；
- 对计算机系统的未授权访问或非法入侵；
- 盗用；
- 拥有或分发非法内容（例如色情等）；
- 拒绝服务（DoS、DDoS）攻击；
- 商业关系的侵权冲突；
- 敲诈；
- 不当使用；
- 其证据可存储在计算机介质中的任何非法行为（如欺骗、恐吓）等。




### 3.3.2 事件分级（四级，背数字）

| 级别 | 判据 |
| --- | --- |
| 四级 / 一般 | 业务中断 < 10 分钟，无数据损坏 |
| 三级 / 较大 | 业务中断 10–30 分钟，无数据损坏 |
| 二级 / 重大 | 业务中断 30–60 分钟，或数据损坏但可恢复 |
| 一级 / 特别重大 | 业务中断 > 60 分钟，或数据无法恢复，或重要数据泄露 |

- 特殊时期（如重大活动），事件级别在原基础上**提升一级**（特别重大除外）。
- **10、30、60 是分割点**。

**计算机安全事件分类**

# 事件分类

- **计算机病毒事件：**病毒指“编制者在计算机程序中插入的破坏计算机功能或者破坏数据，影响计算机使用并且能够自我复制的一组计算机指令或者程序代码。
- **蠕虫事件：**指网络蠕虫，其表现形式为，内外网主机遭受恶意代码破坏或从外网发起对网络的蠕虫感染。
- **木马事件：**是指通过特定的程序（木马程序）来控制另一台计算机。木马通常有两个可执行程序：一个是控制端，另一个是被控制端。
- **僵尸网络事件：**是指采用一种或多种传播手段，将大量主机感染bot程序（僵尸程序）病毒，从而在控制者和被感染主机之间所形成的一个可一对多控制的网络。
- **域名劫持事件：**是指通过攻击域名解析服务器（DNS），或伪造域名解析服务器（DNS）的方法，把目标网站域名解析到错误的地址从而实现用户无法访问目标网站的目的。
- **网络仿冒事件：**是指不法分子在互联网上仿冒知名的电子交易站点（如银行或拍卖网站）的网页，诱使用户访问假站点，骗取用户的账号和密码等信息，从而窃取钱财。
- **网页篡改事件：**是指攻击者已经获取了网站的控制权限，将网页篡改为非本网站的页面。

- **网页挂马事件：**是指攻击者已经获取了网站的控制权限，在网站上插入恶意代码，以实现针对所有访问者进行木马攻击事件。
- **拒绝服务攻击事件：**拒绝服务攻击即攻击者想办法让目标机器停止提供服务，是黑客常用的攻击手段之一。
- **后门漏洞事件：**是指攻击者已经获取了网站或服务器权限，为实现长久控制的目的，在网站或服务器上留下可再次进入的后门程序。
- **非授权访问事件：**是指没有预先经过同意，就使用网络或计算机资源，如有意避开系统访问控制机制，对网络设备及资源进行非正常使用，或擅自扩大权限，越权访问信息。它主要有以下几种形式：假冒、身份攻击、非法用户进入网络系统进行违法操作、合法用户以未授权方式进行操作等。
- **垃圾邮件事件：**是指未经用户许可（与用户无关）就强行发送到用户的邮箱中的任何电子邮件。
- **其他网络安全事件：**其它未在上述定义的网络安全事件。

### 3.3.3 应急响应概念和流程（6 阶段，了解）

通常是指一个组织为了应对各种意外事件的发生所做的准备以及在事件发生后所采取的措施。意义：**未雨绸缪 + 亡羊补牢**。

准备 → 检测 → 抑制 → 根除 → 恢复 → 跟进

### 3.3.4 常见应急事件

根据主机收到的攻击的表象可将木马病毒分为四类：

| 类型 | 特征 | 防御策略 |
| --- | --- | --- |
| **勒索病毒**<br>（也叫勒索木马） | 磁盘文件被加密，<br>一旦完成勒索过程则无法恢复文件 | 以预防为主，安装杀毒软件，做好主机防黑工作，<br>及时打补丁，对重要文件要及时隔离备份 |
| **挖矿木马** | CPU 和 GPU 异常占用过高，<br>且有对矿池地址的解析 | 可有落地文件实现，也可通过 WMI<br>等无落地文件实现 |
| **远控木马** | 一直是 APT（高级持续性威胁）<br>攻击的主流，复杂程度高 | 集成了攻击模块、控制模块、持久化模块等，且有<br>C2（命令与控制）服务器 |
| **普通木马** | 指除上述类型之外的其他木马类型 | — |

# 4. 网络空间安全技术体系与技术

## 4.1 考点 1：开放系统互连安全体系结构（OSI）

**安全机制**：用来保护或保障信息系统安全的一种或一类技术的总称。

**安全服务**：加强数据处理系统和信息传输安全性的一类服务，其目的在于利用一种或多种安全机制保障信息系统安全或信息系统安全可靠运行。

### 4.1.1 五大安全服务（功能，做什么）

| 服务 | 目的 |
| --- | --- |
| 鉴别服务 | 提供对通信中对等实体和数据来源的鉴别，对抗假冒威胁 |
| 访问控制服务 | 提供保护以对抗开放系统互连可访问资源的非授权使用 |
| 数据机密性服务 | 对数据提供保护使之不被非授权地泄漏 |
| 数据完整性服务 | 针对有连接或无连接条件下，对数据进行完整性检验，防止非法篡改、插入、替换或删除 |
| 抗抵赖性服务 | 为通信双方提供证据，防止对已发生通信行为的否认 |

### 4.1.2 八大安全机制（手段，对应服务，怎么做）

| 机制 | 说明 |
| --- | --- |
| 加密机制 | 提供机密性，是其他机制的基础 |
| 数字签名机制 | 完成签名与验证，实现鉴别、完整性和抗抵赖 |
| 访问控制机制 | 按权限控制资源访问 |
| 数据完整性机制 | 通过附加码验证数据是否被修改 |
| 鉴别交换机制 | 通过密码技术由发送方验证来实现鉴别；通过特定的"握手"协议防止鉴别"重放" |

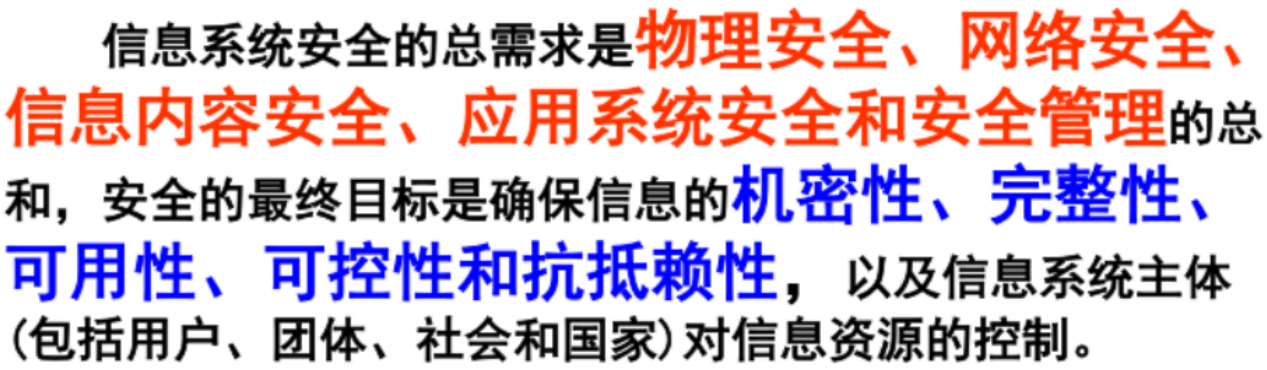
| 机制 | 说明 |
| --- | --- |
| 通信业务填充机制 | 业务分析，特别是基于流量的业务分析是攻击通信系统的主要方法之一。<br>通过通信业务填充来提供各种不同级别的保护（对抗流量分析） |
| 路由选择控制机制 | 针对数据单元的安全性要求，可以提供安全的路由选择方法 |
| 公证机制 | 通过可信第三方机构，实现对通信数据的完整性、原发性、时间和目的地等内容的公证。<br>一般通过数字签名、加密机制来适应公证机构提供的公证服务 |

### 4.1.3 安全服务与安全机制的联系与区别

在开发系统互连（OSI）安全体系结构中，**安全服务**定义了需要实现的安全目标（如机密性、完整性、身份认证等），而**安全机制**是实现这些安全目标的具体技术手段与方法（如加密、数字签名、访问控制等）。

- **联系**：安全机制是安全服务的实现基础，一种安全服务可能需要多种安全机制协同实现，而一种安全机制也可为多项安全服务提供支持。
- **区别**：安全服务是从功能与目标角度提出的抽象安全需求，属于"做什么"；安全机制则是从技术实施角度给出的具体解决方案，属于"怎么做"。
- 二者共同构成了一个从目标到实现、从抽象到具体的完整安全技术体系。

## 4.2 考点 2：信息系统安全体系框架




### 4.2.1 总体框架构成

完整的信息系统安全体系由**技术体系、组织机构体系和管理体系**共同构建。

### 4.2.2 技术体系、组织机构体系和管理体系

**核心原则："三分技术，七分管理"，管理与技术并重。**

## 技术体系

1）**物理安全技术**。信息系统的建筑物、机房条件及硬件设备条件满足信息系统的机械防护安全；通过对电力供应设备以及信息系统组件的抗电磁干扰和电磁泄露性能的选择性措施达到相应的安全目的。物理安全技术运用于物理保障环境（含系统组件的物理环境）。

2）**系统安全技术**。通过对信息系统与安全相关组件的操作系统的安全性选择措施或自主控制，使信息系统安全组件的软件工作平台达到相应的安全等级，一方面避免操作平台自身的脆弱性和漏洞引发的风险，另一方面阻塞任何形式的非授权行为对信息系统安全组件的入侵或接管系统管理权。

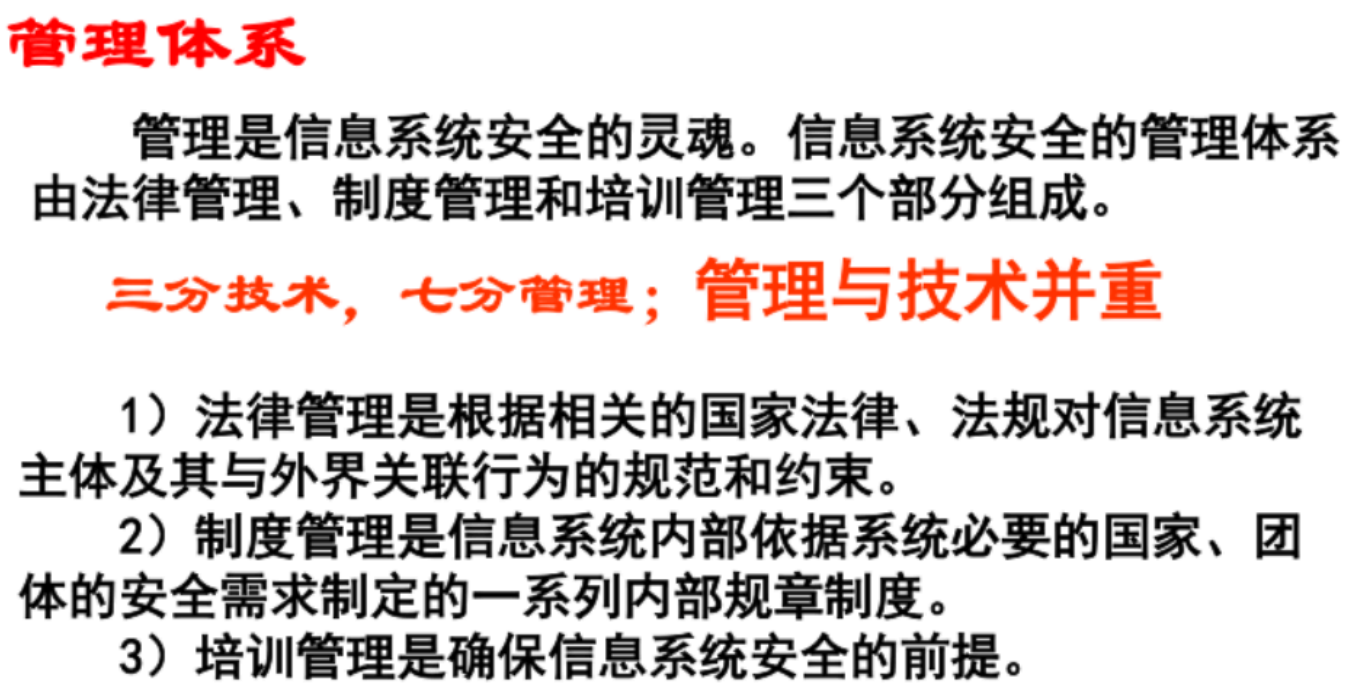
## 组织机构体系

组织机构体系是信息系统安全的组织保障系统，由**机构、岗位和人事三个模块**构成一个体系。

机构的设置分为三个层次：决策层、管理层和执行层

岗位是信息系统安全管理机关根据系统安全需要设定的负责某一个或某几个安全事务的职位

人事机构是根据管理机构设定的岗位，对岗位上在职、待职和离职的雇员进行素质教育、业绩考核和安全监管的机构。




> 可能考名词解释，比如**法律管理**是什么?

### 4.2.3 法律法规与合规义务（法律管理的落地）

上面管理体系中的**法律管理**，落地就是我国网络安全法律体系。当前以三部法律为骨架：

| 法律 | 定位与核心 |
| --- | --- |
| **《网络安全法》** | 网络安全领域的**基础性法律**，确立网络运行安全、**等级保护制度**、**关键信息基础设施（CII）保护**等基本制度 |
| **《数据安全法》** | 确立**数据安全与发展并重**的原则，针对"数据处理活动"本身立法 |
| **《个人信息保护法》** | 专门规范**个人信息处理活动**，保护公民个人权益 |

**《网络安全法》：网络运营者的安全保护义务**

"**网络运营者**"是法定主体，包括网络的所有者、管理者和网络服务提供者。其义务可归纳为六条：

1. 制定内部安全管理制度和操作规程，确定网络安全负责人
2. 采取防范计算机病毒和网络攻击、网络侵入等危害网络安全行为的技术措施
3. 采取监测、记录网络运行状态与网络安全事件的技术措施，并按规定**留存相关网络日志不少于六个月**
4. 采用**数据分类**、重要数据**备份与加密**等措施，保障数据安全
5. 制定网络安全事件**应急预案**，并定期进行演练
6. 法律法规规定的其他义务

**关键信息基础设施（CII）运营者的特别义务**：单独设置安全管理机构和安全管理负责人；采购网络产品和服务可能影响国家安全的，须通过**国家安全审查**。

**《数据安全法》：数据全生命周期安全**

- 基本原则：**数据安全与发展并重**（统筹协调安全与发展）
- 基本制度：**数据分类分级保护制度**；建立数据安全风险评估、监测预警、信息共享、事件报告等机制

- 主体义务：开展数据处理活动应建立健全**全流程**数据安全管理制度、组织落实数据安全教育培训、采取相应技术措施；**重要数据**处理者应明确数据安全负责人和管理机构
- 全生命周期：收集、存储、使用、加工、传输、提供、公开——**每个环节都要落实安全措施**

**《个人信息保护法》：三大基本原则**

| 原则 | 要求 |
| --- | --- |
| **告知—同意** | 处理个人信息前须明示处理目的、方式和范围，并取得个人同意 |
| **最小必要** | 只收集与处理目的**直接相关、影响最小**的个人信息，不得过度收集 |
| 单独同意 | **敏感个人信息**（生物识别、宗教信仰、医疗健康、金融账户、行踪轨迹等）须取得单独同意 |

**等级保护制度（等保 2.0）**

《网络安全法》确立了**国家实行网络安全等级保护制度**，要求网络运营者按制度履行安全保护义务。等保测评的产出即**合规性**证明，与 §2.1.3 的风险评估并列，是做合规性评估的两条主线。

**安全事件的责任主体认定**

| 主体 | 承担的责任 |
| --- | --- |
| **网络运营者（单位）** | 承担**主体责任**——未履行安全保护义务导致安全事件的，<br>依法承担相应法律责任 |
| **直接负责的主管人员和其他直接责任人员** | 依法承担相应责任（单位内部追责 + 行政处罚） |
| 攻击者 / 实施违法犯罪行为的个人或组织 | 依《刑法》《治安管理处罚法》等追究刑事责任 |

> 问"安全事件的责任主体"时，标准答案是**网络运营者**（而不是笼统说"公司"或"个人"）；只有当行为人构成违法犯罪时，才转向追究个人刑责。

**网络管理者应履行的职责清单（可按序整体作答）**

1. **建制度**——制定内部安全管理制度、操作规程与安全责任制，确定网络安全负责人
2. **定等级**——按等级保护制度开展定级、备案、测评与整改
3. **防威胁**——部署防范病毒木马、入侵检测、防火墙、访问控制等技术措施
4. **管数据**——数据分类分级、重要数据备份与加密、个人信息最小必要处理
5. **留证据**——开启日志记录并按规定留存网络日志（不少于六个月）
6. **重应急**——制定应急预案并定期演练；事件发生后及时处置、**向上级主管部门报告**并配合调查
7. **重培训**——开展全员安全意识培训与考核

> 写的时候按这个顺序往下走：**制度 → 定级 → 技术 → 数据 → 取证 → 应急 → 培训**。七条下来覆盖完整，不容易漏。

## 4.3 考点 3：网络空间安全技术层次分类

**五层（和网络空间安全的四层次模型区分开！）**

# 4.5.4 网络空间安全技术层次分类

安全防范技术体系划分为物理层安全、系统层安全、网络层安全、应用层安全和管理层安全等五个层次。

1）**物理安全技术（物理层安全）**：该层次的安全包括通信线路的安全、物理设备的安全、机房的安全等。物理层的安全主要体现在通信线路的可靠性（线路备份、网管软件、传输介质），软硬件设备安全性（替换设备、拆卸设备、增加设备），设备的备份，防灾害能力，防干扰能力，设备的运行环境（温度、湿度、烟尘），不间断电源保障。

2）**系统安全技术（操作系统的安全性）**：该层次的安全问题来自网络内使用的操作系统的安全，如Windows系列、Unix等。主要表现在三个方面：一是操作系统本身的缺陷带来的威胁，主要包括身份鉴别、访问控制、系统漏洞等；二是对操作系统的安全配置问题；三是病毒对操作系统的威胁。

3.com
网络空间安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING
四川大学
SICHUAN UNIVERSITY

3）**网络安全技术（网络层安全）**：主要体现在网络方面的安全性，包括网络层身份鉴别、网络资源的访问控制、数据传输的机密性与完整性、远程接入的安全、域名系统的安全、路由系统的安全、入侵检测、网络设施防病毒等。

4）**应用安全技术（应用层安全）**：主要由提供服务所采用的应用软件和数据的安全性产生，包括Web服务、电子邮件系统、DNS等。此外，还包括病毒对系统的威胁。

5）**管理安全性（管理层安全）**：安全管理包括安全技术和设备的管理、安全管理制度、部门与人员的组织规则等。管理的制度化极大程度地影响着整个网络的安全，严格的安全管理制度、明确的部门安全职责划分、合理的人员角色配置都可以在很大程度上降低其他

层次的安全漏洞。

## 4.4 考点 4：核心安全技术机制详解

### 4.4.1 加密机制

| 类型 | 说明 |
| --- | --- |
| 对称加密（如 AES） | 加解密使用**同一密钥**，速度快 |
| 非对称加密（公钥密码，如 RSA） | 使用公钥（$K_U$）和私钥（$K_R$）对 |

- **公钥**：可公开，用于加密数据以实现机密性，或验证签名。
- **私钥**：必须保密，用于解密数据，或生成数字签名。

**非对称加密的适用边界（高频易错点）**

非对称密码的运算代价是**大数模幂**，比对称密码慢好几个数量级，因此它**不能用来直接加密大块数据**。它的真正用途只有三类：

| 用途 | 说明 |
| --- | --- |
| **数字签名** | 用私钥签名、公钥验证，担保完整性与抗抵赖（见 §4.4.3） |
| **密钥分发** | 加密会话密钥，在不可信信道上安全协商出共享密钥 |
| **加密少量关键数据** | 只对小尺寸数据（如会话密钥）直接使用 |

**混合加密（实际系统的通行做法）**：用非对称加密安全地传递**对称会话密钥**，再用对称加密传输**实际的大块数据**——既拿到了非对称的密钥分发便利，又拿到了对称的高效率。这也是"TLS/HTTPS 握手用非对称、传输内容用对称"的原理。

> 题目问"非对称加密（如 RSA）的**目的不包括**什么"时，标准答案就是"**直接加密大量数据**"。凡涉及"大块数据 / 长消息 / 高带宽传输"，一律排除非对称方案。

**基于公钥密码的鉴别过程**

1. 发送方用自己的私钥对消息（或摘要）签名。
2. 接收方用发送方的公钥验证签名。
3. 若验证成功，则证明消息来源真实且未被篡改，实现了身份鉴别和数据完整性验证。

### 4.4.2 消息鉴别

**目的**：验证消息来源的真实性和内容的完整性。三种方式：

| 方式 | 鉴别标识 |
| --- | --- |
| 消息加密 | 以整个消息的密文作为鉴别标识 |
| 哈希函数 | 生成消息的散列值（摘要）作为鉴别标识 |
| 消息鉴别码（MAC） | 一个公开函数加上共享密钥生成一个固定长度的值（密码校验和）作为鉴别标识 |

**消息鉴别码（MAC）特点**：使用共享密钥生成，提供鉴别和完整性保护，但**不提供机密性**；MAC 函数不需要可逆特性。

### 4.4.3 数字签名机制（基于 RSA）

**签名过程**

1. 对消息 $M$ 计算哈希值 $H(M)$。
2. 用发送者私钥 $d$ 加密哈希值：$s = H(m)^d \bmod n$，$s$ 即为签名。

**验证过程**

1. 用发送者**公钥** $(e, n)$ 解密签名：$H_1 = s^e \bmod n$。
2. 独立计算收到消息的哈希值 $H(m)$。
3. 比较 $H_1 = H(m)$，相等则验证成功。

**作用**：具有不可伪造性、抗抵赖性，并保证消息完整性。

**数字签名与加密的三点根本区别（高频易错辨析）**

| 对比项 | 加密 | 数字签名 |
| --- | --- | --- |
| **目的** | **机密性**——防别人看 | **完整性 + 身份鉴别 + 抗抵赖**——防篡改、防否认 |
| **密钥方向** | 公钥加密 → 私钥解密 | 私钥签名 → 公钥验证 |
| **用谁的私钥** | **接收方**的私钥 | **发送方**的私钥 |

**结论：数字签名不提供机密性。** 签名是对**消息摘要**做的运算，而摘要是公开可算的——任何人拿到原消息都能自行算出摘要，再用发送方公钥验证。签名的作用是证明"**是谁发的、内容没被改**"，而不是"不让别人看见内容"。签了名并不隐藏原文。

**若既需要抗抵赖又需要保密**，必须**先签名后加密**：发送方先对摘要签名，再把"消息 + 签名"整体加密后发出；接收方先解密、再验签。反过来（先加密再签名）会让签名无法覆盖密文完整性。

> 看到"**加密**"和"**签名**"同时出现在否定选项里，优先考虑签名，因为签名本来就不是为保密设计的。（参见 §4.4.2，MAC 同样**不提供机密性**。）

### 4.4.4 【应试背诵要点与预测考点】

- **名词解释**：安全服务、安全机制、数字签名、MAC、抗抵赖性。
- **简答题**：
  - 列出 OSI 安全体系结构的五种安全服务及其基本目的。
  - 解释"公钥加密，私钥解密"与"私钥签名，公钥验证"的区别与用途。
  - 简述消息鉴别的三种基本方式。
  - 阐述"三分技术，七分管理"的含义及管理体系的三个组成部分。
- **流程描述题**：描述基于 RSA 的数字签名生成与验证步骤。
- **对比题**：对比对称加密与非对称加密的特点；对比数字签名与消息鉴别码（MAC）的功能异同。

# 5. 鉴别技术

## 5.1 鉴别（Authentication）基本概念

**定义**：确认一个实体（如用户、进程）就是它所声明的身份。这是最重要的安全服务之一，其他安全服务都依赖于它。

**目的**：解决身份欺诈问题，让验证者获得对声称者所声称身份的信任。

**与其它机制的关系**

| 机制 | 与鉴别的关系 |
| --- | --- |
| 访问控制 | 依赖确知的身份来控制访问 |
| 数据完整性 | 可与数据完整性机制结合，提供数据起源鉴别 |
| 审计机制 | 为审计记录提供确知的身份，支持责任认定 |

## 5.2 对身份鉴别系统的要求

**（1）–（6）必须要求**

1. 验证者正确识别合法申请者的概率极大化。
2. 不具有可传递性（Transferability）。
3. 攻击者伪装成申请者欺骗验证者成功的概率要小到可以忽略的程度。
4. 计算有效性。
5. 通信有效性。
6. 秘密参数能安全存储。

**（7）–（10）增量需求**

7. 交互识别。
8. 第三方的实时参与。
9. 第三方的可信赖性。
10. 可证明的安全性。

## 5.3 被动攻击与主动攻击的区别

| 类型 | 含义 |
| --- | --- |
| 被动攻击 | 如窃听，仅监听或监控数据传输，**不对数据进行篡改** |
| 主动攻击 | 如阻断、伪造、重放，涉及对数据流的篡改或创建虚假数据流，对数据进行了篡改 |

## 5.4 实现身份鉴别的 4 途径

| 途径 | 含义 | 举例 |
| --- | --- | --- |
| 基于你所知道的（What you know） | 知识 | 口令、密码 |
| 基于你所拥有的（What you have） | 持有物 | 智能卡、令牌、身份证、钥匙、信用卡 |
| 基于你的个人特征（What you are） | 生物特征 | 其假设是每个人的生理特征具有唯一性；如指纹、虹膜、声音、手型、脸型、笔迹签名等 |
| 双因素/多因素认证 | 结合以上多种途径，安全性更高 | RSA SecurID 双因素口令由用户 PIN 码和令牌生成的动态码组合构成 |

## 5.5 鉴别技术分类：按保护等级（0–4 级）

| 级别 | 机制 | 抗泄露 | 抗重放范围 |
| --- | --- | --- | --- |
| **0 级**（无保护） | 直接发送可辨别标识符和申请鉴别信息（AI） | ✗ | ✗<br>（易暴露和受重放攻击） |
| **1 级**（抗泄露保护） | 发送经变换函数处理后的结果<br>（如单向函数散列值），不直接传输申请 AI | ✓ | ✗（仍怕重放） |
| **2 级**（抗泄露 +<br>防对不同验证者重放） | 在变换函数输入中加入"验证者标识"，<br>防止攻击者将交互信息重放给其他验证者 | ✓ | 不同验证者 ✓ /<br>同一验证者 ✗ |
| **3 级**（抗泄露 +<br>防对同一验证者重放） | 在变换函数输入中加入"唯一数"（如随机数、<br>时间戳），防止攻击者将信息重放给同一个验证者 | ✓ | ✓<br>（防对同一验证者重放） |
| **4 级**（抗泄露 +<br>防对任何验证者重放） | 目标最强。常用质询-应答机制实现 | ✓ | ✓（任何验证者） |

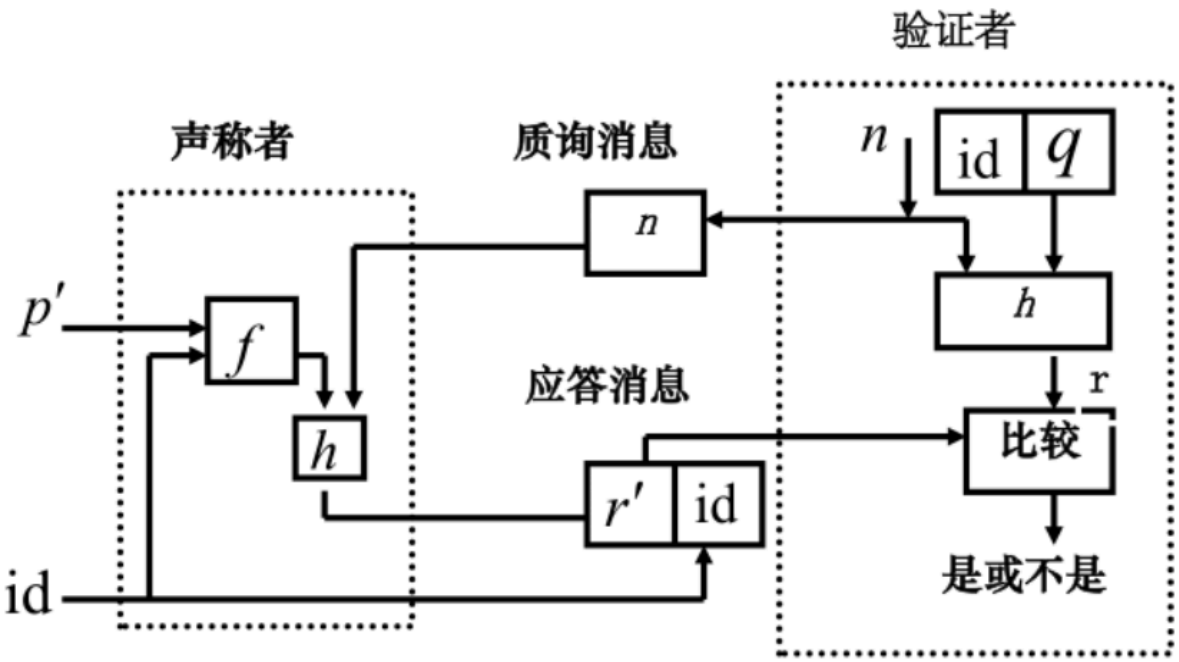
**4 级质询-应答机制**：验证者发送一个随机质询（挑战）给声称者，声称者用其秘密信息（如密钥）对该质询进行变换（如加密、计算 MAC）后作为响应返回，验证者校验响应是否正确。此过程确保每次鉴别交换信息都不同，有效抵抗重放。

## 5.6 基于质询-应答的身份鉴别技术

这是**第四级身份鉴别**。

**过程描述**

1. 验证者生成一个质询消息 $n$（随机值，challenge）发送给声称者。
2. 声称者收到质询 $n$ 后，结合自身身份标识 $id$ 和与验证者共享的秘密 $p'$，先通过函数 $f$ 计算中间值，再经哈希函数 $h$ 生成响应 $r'$。
3. 声称者将响应 $(r', id)$ 返回给验证者。
4. 验证者根据接收到的 $id$ 查询数据库中对应的预存值 $q$（通常为 $h(p')$ 或相关派生值），结合原始质询 $n$，使用相同的哈希函数 $h$ 计算期望响应 $r$，若 $r = r'$ 则认证成功，否则拒绝。




质询-应答身份鉴别技术示意图

**安全性**：依赖于质询的不可预测性和不重复性，能有效防止口令窃听和重放攻击。

## 5.7 MAC 的计算方法与校验

**MAC（消息鉴别码）**：用于验证消息的完整性和来源。

**计算方法**：使用一个带密钥的密码校验函数 $f$，对消息 $Z$ 和共享密钥 $K$ 进行计算，得到密码校验值 $f_K(Z)$。

**具体实现**：MAC 的计算可以基于 Hash 算法（如 HMAC）、对称密钥算法或公开密钥算法。

**校验过程**：接收方使用相同的密钥 $K$ 和函数 $f$ 对收到的消息重新计算 MAC，并与收到的 MAC 值比较。若相同，则消息未被篡改且来自合法发送方。

## 5.8 零知识证明（Zero-Knowledge Proof）

**零知识证明思想**：在密码学中，希望一个鉴别协议能够在声称者向验证者证明他身份的同时，没有泄露任何信息。

1、证明者P不提供有意义的信息

2、验证者V相信证明者提供的信息

**零知识证明三原则**【最常考，务必背熟】

| 原则 | 口诀 | 含义 |
| --- | --- | --- |
| **完备性** | 真的假不了 | 如果声称者确实拥有所声称的知识（是真的），那么诚实的验证者最终会被说服 |
| **合理性** | 假的真不了 | 如果声称者不拥有所声称的知识（是假的），那么他欺骗验证者接受的概率极低 |

| 原则 | 口诀 | 含义 |
| --- | --- | --- |
| **零知识性** | 只知结果不知秘密 | 在整个证明过程中，验证者除了知道"声称者拥有该知识"这一事实外，<br>不能获得任何关于该知识本身的额外信息 |

**直接证明 vs 间接证明**【选择题高频】

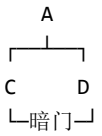
| 方式 | 做法 | 泄漏量 |
| --- | --- | --- |
| **直接证明** | 出示或直接说出秘密本身 | **最大泄漏证明**——秘密一旦说出即完全暴露 |
| **间接证明** | 用**数学方法**证明自己知道秘密 | **零知识**——零知识证明属于间接证明 |

看到"哪种证明会泄漏秘密"→ 直接证明（最大泄漏）；看到"零知识证明属于哪种"→ 间接证明。

**经典例子**（记原理即可，无需背细节）

| 例子 | 原理 |
| --- | --- |
| **山洞（洞穴）问题** | 秘密是"能否打开 C、D 之间的暗门"，用反复随机指路来验证（唯一需要算，见下） |
| 色盲验证红绿双球 | 声称者靠**语言**描述手中球的颜色（不看球），只有真色盲能描述对 |
| 皇帝的新衣 | 全场只有真看不见的人敢说"我没看见"——不敢说即暴露 |
| 数独问题 | 只证明自己填出了正确解，不泄露解法 |
| 地图三色问题 | 只证明存在三染色方案，不泄露具体着色 |
| 阿里巴巴与四十大盗 | ZKP 的**动机来源**（纯故事案例，一般不考） |

**山洞（洞穴）问题**【本节唯一需要算的点】




协议：① 验证者 V 站在 A 点，声称者 P 进入洞中走到 C 或 D（V 不知道是哪个）② V 走到 B 点，**随机**喊"从左通道出"或"从右通道出" ③ P 按要求从对应通道走出 ④ 重复 $n$ 轮。

| 情况 | $n$ 轮全对的概率 |
| --- | --- |
| P **知道**暗门位置 | $1$（每轮必对） |
| P **不知道**（纯蒙） | $(1/2)^n$ |

$P=(1/2)^n$，取 $n=16$ 时 $P=1/65536\approx 1.5\times 10^{-5}$——蒙对概率已低到可忽略，故 P 几乎必然知道暗门位置。注意验证者**始终不知道**暗门在哪，只知道"P 知道"，这正是零知识性的体现。

**延伸**（了解层级，可能出名词解释）

- **NPC 归约**：任意数学命题（如哥德巴赫猜想）都可转换为 **NPC 问题**（如三染色问题），因此**证明了三染色即证明了原命题成立**。

- **典型零知识鉴别协议**：基于计算模 $n$ 平方根困难性的 **Fiat-Shamir**、**Fiege-Fiat-Shamir** 协议；基于离散对数困难性的 **Needham-Schroeder** 协议——均属**质询-应答**框架的变体，可与本篇 §5.6 联记。

# 6. 访问控制

## 6.1 访问控制的概念与目标

**访问控制概念**：针对越权使用资源的防御措施。

**目标**：防止对任何资源（计算、通信、信息资源）进行未授权的访问，使资源在授权范围内使用，决定用户及其程序能做什么。

**最小授权原则**：是访问控制思想的体现，指只授予主体（用户、程序）完成其任务所必需的最小权限，避免权限过度扩散。

**未授权访问**：包括未经授权的使用、泄露、修改、销毁信息以及颁发指令等。两个具体实例：非法用户对系统资源的使用、合法用户对系统资源的非法使用。

## 6.2 访问控制的两个重要过程

| 步骤 | 作用 |
| --- | --- |
| 第一步：**鉴别** | 检验主体的合法身份 |
| 第二步：**授权** | 限制用户对资源的访问权限 |

**关系**：身份鉴别是访问控制的前提。

## 6.3 核心概念

| 概念 | 定义 |
| --- | --- |
| 主体 (Subject) | 发起操作的主动实体，如用户、程序、进程 |
| 客体 (Object) | 被操作的被动实体，即需要保护的资源，如文件、数据库 |
| 访问 (Access) | 主体对客体的操作，如读、写、修改、删除 |
| 授权 | 规定主体可以对客体执行的操作（如读、写、执行、拒绝访问） |

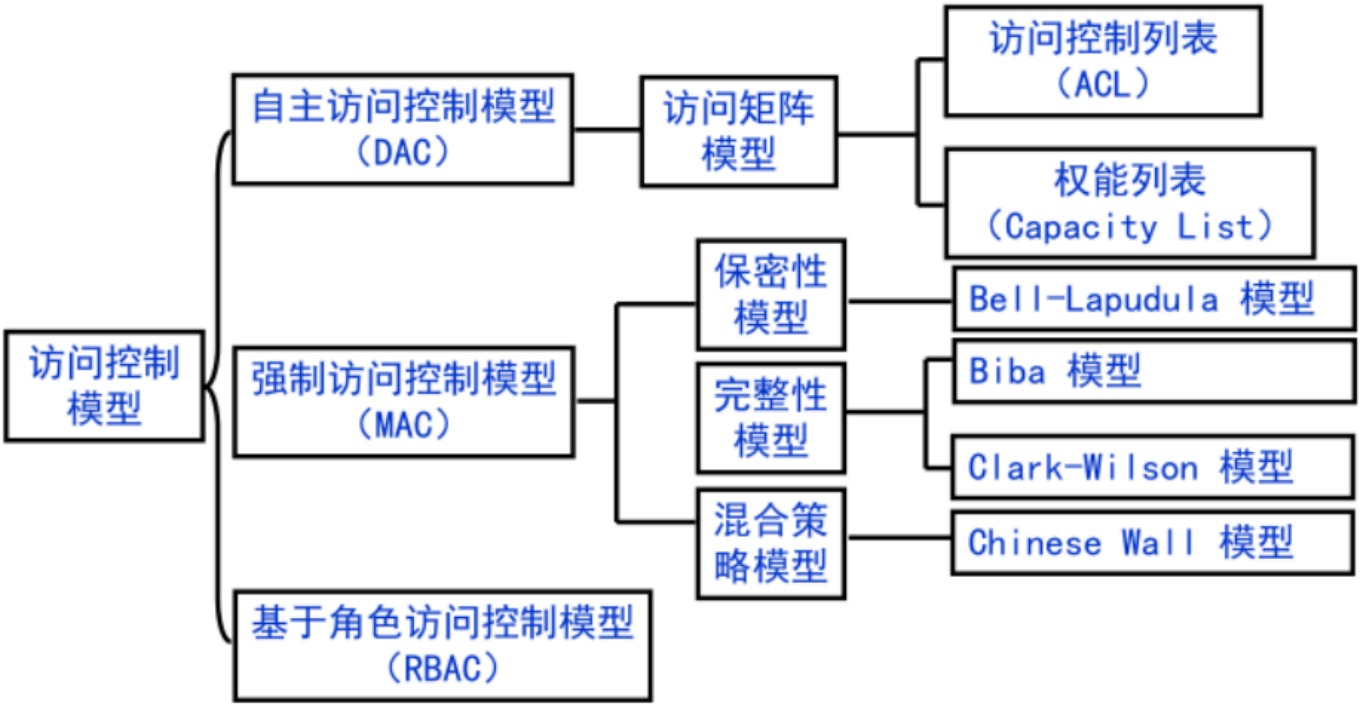
## 主体与客体之间的关系

- **主体**：接收客体相关信息和数据，也可能改变客体相关信息
- 一个主体为了完成任务，可以创建另外的主体，这些主体可以在网络中不同的计算机上运行，并由父主体控制它们
- **客体**：始终是提供、驻留信息或数据的实体
- 主体和客体的关系是相对的，角色可以互换

### 6.4 访问控制模型分类

主要分为：自主访问控制模型、强制访问控制模型、基于角色的访问控制模型。

## 访问控制模型的分类



## 6.5 自主访问控制模型（DAC）

**是什么**：允许客体的属主（创建者）自主决定其他主体对该客体的访问权限。是一种**分布式授权管理模式**。

**应用场景**：常用于商业系统。

**优点**

- a. 根据主体的身份和访问权限进行决策
- b. 具有某种访问能力的主体能够自主地将访问权的某个子集授予其它主体
- c. 灵活性高，易用性和可扩展性好，被大量采用

**缺点**

- 安全性不高。
- **无法控制信息流动**：权限可能被传递，使不具备权限的用户获得访问权。
- 面临**特洛伊木马**威胁：木马可能利用用户的权限进行非法操作。

**实现机制与方法**：基于访问控制表/矩阵。

| 方法 | 关联对象 | 特点 |
| --- | --- | --- |
| 访问控制表 | 与客体关联，列出可访问它的主体及权限 | 便于管理客体权限，但查看主体所有权限困难 |
| 访问能力表 | 与主体关联，列出该主体可访问的客体及权限 | 便于查看主体权限，但管理客体权限困难 |
| 访问控制矩阵 | 从数学上描述主体、客体和访问权限的关系 | 矩阵的行是能力表，列是访问控制表 |

## 6.6 强制访问控制模型（MAC）

**是什么**：主体对客体的访问由系统强制控制，客体的属主无权决定。主体和客体被分配固定的安全属性（安全级别/标签），只有满足特定规则时才允许访问。可与自主访问控制结合使用。

**应用场景**：军事等安全要求较高的系统。

**强制型访问控制（MAC）特点**：将主体和客体分级，根据主体和客体的级别标记来决定访问模式。其访问控制关系分为：上读/下写（完整性），下读/上写（机密性）。通过**梯度安全标签**实现单向信息流通模式。

### 6.6.1 信息流向规则（核心重点）

**"写"操作代表了信息的流动方向。**

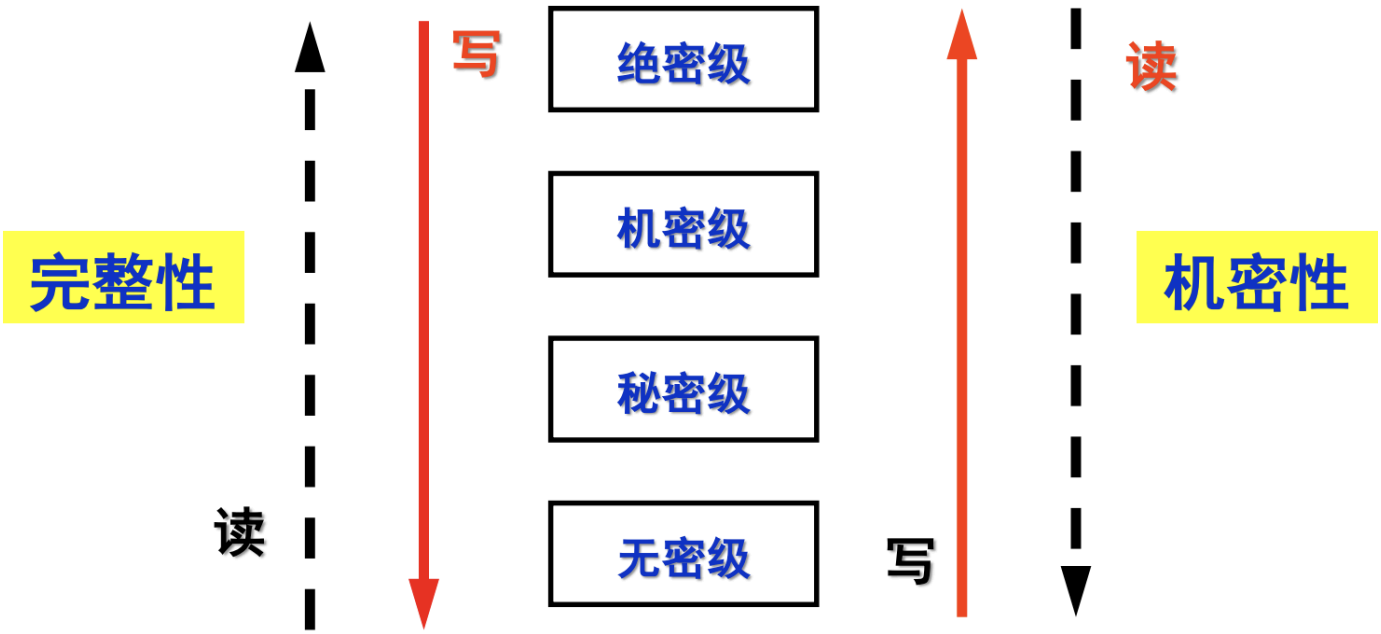
| 规则 | 约束 | 保证的属性 | 典型模型 |
| --- | --- | --- | --- |
| **下读 / 上写**<br>（rd, wr） | 主体级别**高于**客体时可读；主体级别**低于**客体时可写。<br>信息流只能从低级别流向高级别 | 机密性 | Bell-LaPadula（BLP）模型 |
| **上读 / 下写**<br>（ru, wd） | 主体级别**低于**客体时可读；主体级别**高于**客体时可写 | 完整性 | Biba 模型 |

> 选择题会考保证了机密性还是保证了完整性，哪个是机密性哪个是完整性。

## ❖MAC中主体对客体的访问有四种方式

- 下读/上写
- 上读/下写

**“写”代表了信息流动方向**

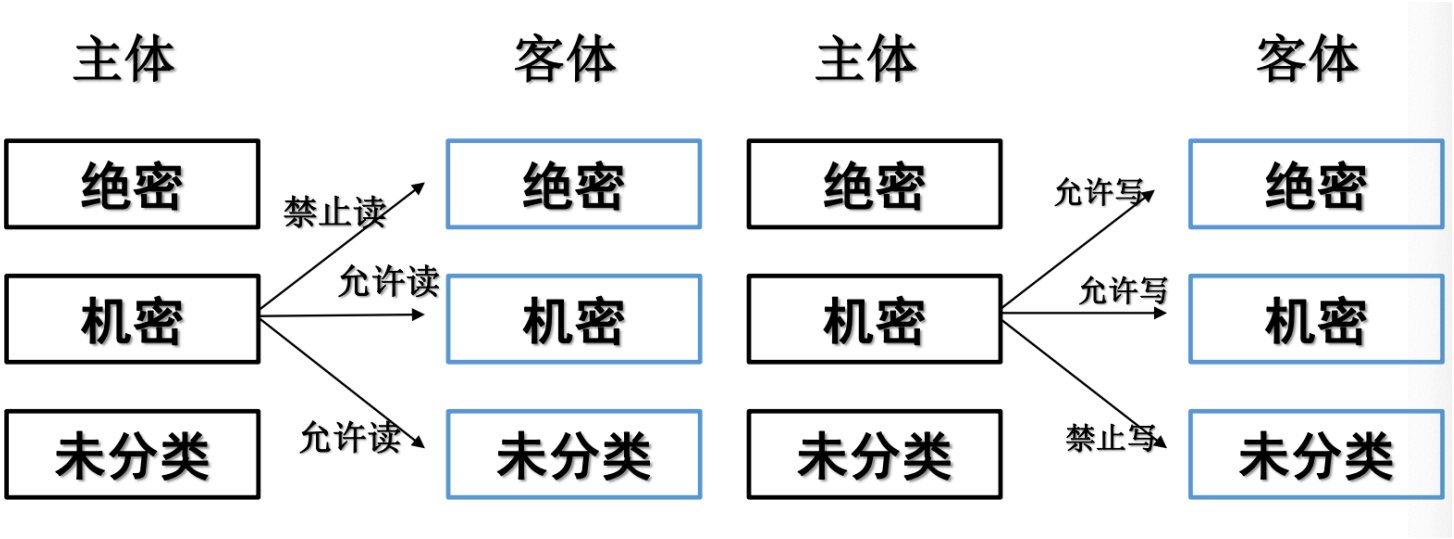



### 6.6.2 四种 MAC 策略规定

- **下读**：用户级别大于文件级别的读操作。
- **上写**：用户级别低于文件级别的写操作。
- **下写**：用户级别大于文件级别的写操作。
- **上读**：用户级别低于文件级别的读操作。

### 6.6.3 常见强制访问控制模型的特点

| 模型 | 特点 |
| --- | --- |
| **Lattice 模型** | 主体的安全级别高于客体的安全级别才能访问；下读、下写 |
| **BLP 模型** | 多级安全模型，通过"下读/上写"规则防止信息从高安全级流向低安全级，保证**机密性** |
| **Biba 模型** | 通过"上读/下写"规则防止低完整性信息污染高完整性信息，保证**完整性** |
| **Clark-Wilson 模型** | 以事务处理为核心的完整性模型，应用于商业系统 |
| **Chinese Wall 模型** | 解决商业利益冲突的安全策略模型 |




## 6.7 基于角色的访问控制（RBAC）

### 6.7.1 基本思想

根据用户所担任的角色来决定用户在系统中的访问权限。用户必须扮演并激活某种角色，才能访问对象或执行某种操作。

**核心是"用户 — 角色 — 权限"三层抽象关系**

```
用户(User)  ←—多对多—→  角色(Role)  ←—多对多—→  权限(Permission)
```

| 层次 | 含义 | 举例 |
| --- | --- | --- |
| **用户** | 系统中的具体自然人或进程，是安全活动的主体 | 张三 |
| **角色** | **一组职责的集合**，代表职位 | 财务主管、审计员 |
| **权限** | 对客体的具体操作授权 | 读文件、写数据库、批准付款 |

- **用户 ↔ 角色：多对多。**一个用户可同时被授予多个角色；一个角色也可赋予多个用户。
- **角色 ↔ 权限：多对多。**一个角色对应一组权限，同一个权限也可被多个角色共享。
- **权限可继承**：角色可以继承其他角色的权限，权限逐级累加。
- **对应关系动态可调**：系统运行期间可随时调整用户与角色、角色与权限的映射；新增用户时只需挂到已有角色，不必逐条重新授权——这正是 RBAC 相对传统 ACL 的核心优势。

### 6.7.2 特点

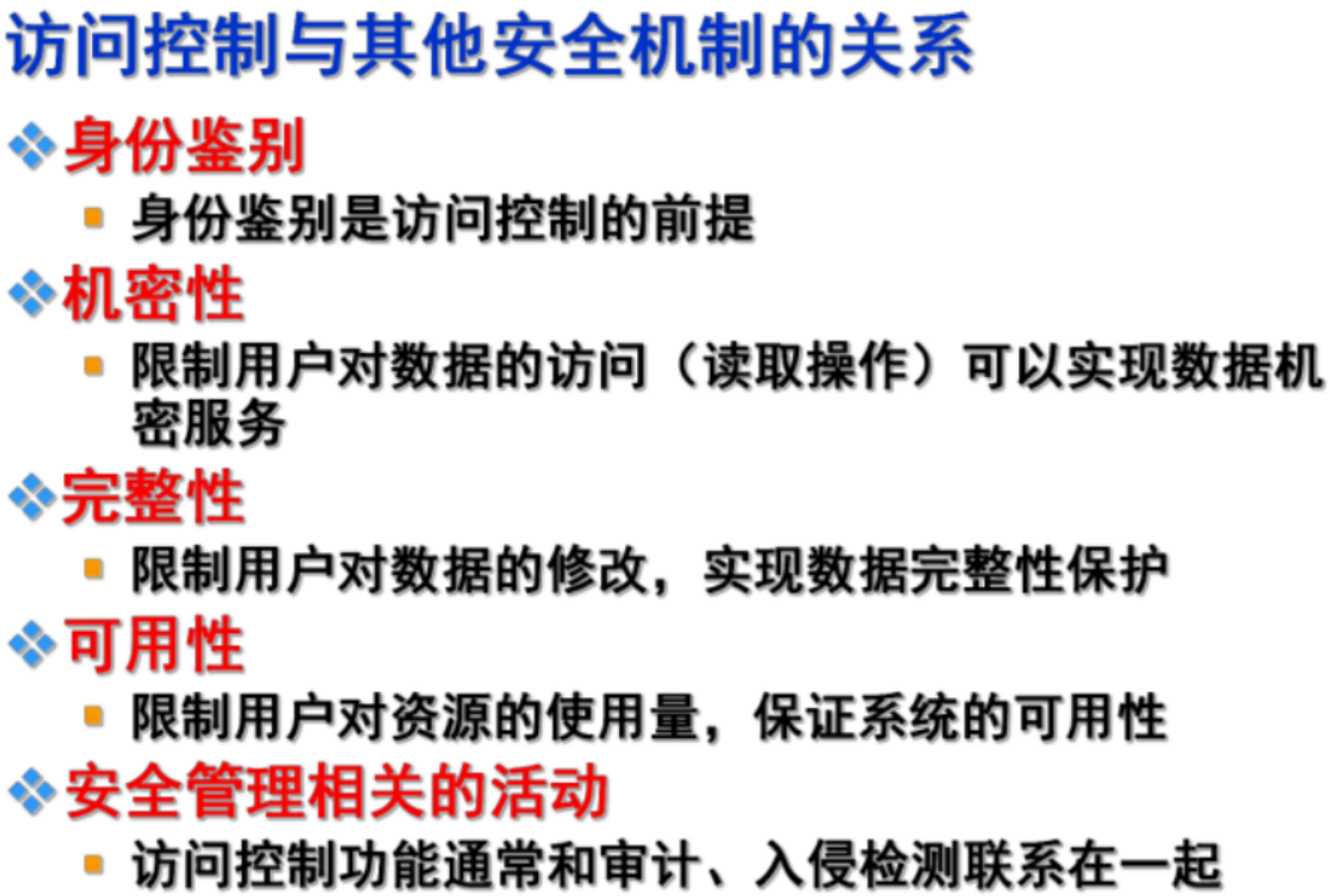
- 便于**授权管理**，如系统管理员需要修改系统设置等内容时，必须有几个不同角色的用户到场方能操作，增强了安全性
- 便于**处理工作分级**，如文件等资源分级管理
- **利于安全约束**，容易实现各种安全策略，如最小特权、职责分离等
- 便于**任务分担**，不同角色完成不同的任务

**两大核心安全属性**

- **最小特权（Least Privilege）**：每个用户只被授予完成其职责所**必需的最小权限集**，权限随职务变动而及时收回。
- **职责分离（Separation of Duty, SoD）**：把**不相容的职责拆给不同角色**，使任何单一用户都无法独立完成敏感操作。例如"发起付款"与"批准付款"分属两个角色，必须两个角色配合才能生效——即使某个账号被盗，单点也无法造成资金损失。

> 简答主干：RBAC 就是在用户和权限之间**插入"角色"这一层**，把要管理的对象从"给每个人单独授权"变成"给角色授权"。好处是人员进出只需改角色，不必逐条重设权限，从而低成本地实现最小特权和职责分离。

## 6.8 其他没那么重点但可能考的




**零信任（Zero Trust）**【本系列课件未设专章，按通用定义记三条核心原则即可】

| 核心原则 | 含义 |
| --- | --- |
| **永不信任，始终验证**（Never Trust, Always Verify） | 默认**不信任**任何内外部用户与设备，一律先验证后访问 |
| **最小权限访问** | 按需授权——与本篇 §6.1 最小授权原则、§6.7 最小特权（Least Privilege）本就是同一考点 |
| **持续验证与动态访问控制** | 不是登录一次就放行，全程持续评估身份、设备与行为 |

- **易混提醒**：可信计算中的"**信任根、信任链**"属于**可信计算**概念，与零信任"默认不信任"的方向**正好相反**，两者别混为一谈。
- **与网络准入控制（NAC）的关系**：NAC 是零信任的前身与特例——NAC 只解决"能否进入网络"这一次鉴权，零信任把它泛化为"**每一个访问请求都重新鉴权**"，见网络安全（下） §9.4。

**网络安全（上）完。**下一篇：网络安全（下）——防火墙、入侵检测、VPN 与系统安全